Home Work Day 8

1. Read OWASP
2. CWT
3. CVE
4. CVSS
5. NIST
6. NSC
7. OSSTMM

Test Syllabus

Day 1 - Day 8

OWASP {Open World Wide Application Security Project}

- 2001 - (mark curphy) started.
- Knowledge, experience, theory, tool.
- Web Goat, Juice shop -> Vuln Project for practice
- Open Source & Online Community
- OWASP Zap tool -> free Pentesting tool.
- "OWASP Top 10".

1 -> Broken Access control :-> website login -> Url user id change 1234 -> 124 -> Id changed of user (profile changed)
- when every request is not verified in server
- If attacker get direct url link it will be a jackpot.
- classic IDOR

2 -> Cryptographic Weakness :-> encryption key in code
- Reverse engineer get the key

3 -> Injection :-> SQL injection (user put database cmd in input -> cmd runs)
- Security by parameter questions.
- Secure by threat modeling.

4 -> Insecure coding :- Brute Force attack on Password
- secure by threat modeling

5 -> Security misconfiguration :-> Cloud Server -> S3 Bucket -> Public set -> whole Data open
- Default Password not changed
- Sys Info

6 -> Old & weak software use :->

7 -> Authentication & Identification :-> Credential stuffing by leak Database & Session hijacking

8 -> Software & Data Integrity weakness -> Supply chain attack (eg Solar winds)

9 -> Security login & weakness in Surveillance } - 200 days for hacker

10 -> Server Side Request Forgery :-> cg/(capital I)
(SSRF)

* OWASP AI top 10 list.

* OWASP - Non profit Global Community.

* OWASP Top 10 :-

* Attack Anatomy :

1. Broken Access Control :-> 94% presence.
2. Software Data Intrigrity Failure :-> eg Solar Winds (SSRF)
3. Server Side Request Forgery :-> eg capital one Breach (SSRF)

* OWASP ZAP : Proxy tool.

US NAVY CWT :- Cyber Warfare Technicians

-> Gov sanctioned Hackers
-> US Navy Special Role
-> Attack vs Defence. Game

RED	BLUE
H12A Exploitation Analyst	H30A Cyber Defence Analyst

-> Recruit training. -> A School (Basic Trng) -> Follow-on-Training (Adv Trng)

-> The Job is not physically hard... but it can tire the mind.
-> zero Day vuln

DAY 9

* - Scanning & Enumeration

1st Step - Ping

nmap <IP> - Basic scan

nmap -sn Ping sweep.
-Pn Port discovery.
-sS

filtered -
unfiltered -
Open unfiltered -

THM Lab Relevant

Port 80 open
↳ Robots.txt
↳ source code.
↳ login forms
↳ API
↳ file uploads

SMB Port No 139 & 445
↳ enum4linux -a <IP>
↳ smbclient -L <IP>

* cyber chef.
HackerTricks.

HamWorld.
* Relevant
* Nmap - all Labs

Scanning & Enumeration Notes (CMS)

Scanning - alive, ports, services
Enumeration - usernames, shares, policies, banners.

→ Network scanning :- • Ping sweep (ICMP scan)
• ARP Scan - local subnet only (LAN)
• TCP/UDP Scans -

→ Filtered - Firewall blocking Packets
Unfiltered - Port accessible, state unknown
Open/filtered - can't determine - no response

→ Vuln Scan Tools : Nessus, OpenVAS, Nikto, Nuclei

→ NMAP :-

- Basic Scan - nmap <IP>
- Scan entire Subnet - nmap 192.168.1.0/24
- Scan IP range - nmap 192.168.1.1-50
- Scan from file - nmap -iL targets.txt

Host Discovery

- Ping sweep (no port scan) - nmap -sn 192.168.1.0/24
- Skip host discovery, treat as up - nmap -Pn 192.168.1.1
- ICMP echo ping - nmap -PE 192.168.1.0/24
- TCP SYN ping on specific port - nmap -PS22,80,443 192.168.1.1
- TCP Ack Ping - nmap -PA80 192.168.1.1
- UDP ping - nmap -PU53 192.168.1.1

★ Use -Pn when target blocks ICMP, many firewalls drop pings but leave ports accessible.

Port Scanning Techniques

FLAG	SCAN TYPE	DESCRIPTION	PRIVILEGE
-sS	TCP SYN (Stealth)	Half opened scan. Doesn't complete handshake, fast & stealthy	Root
-sT	TCP Connect	Full 3 way handshake. Logged by target No root needed	User
-sU	UDP Scan	Scans UDP Ports. Slow. Important for DNS/SNMP/TFTP.	Root
-sF	FIN Scan	Sends FIN Packet, Bypasses some Firewall	Root
-sX	Xmas Scan	FIN+PSH+URG flags. Stealthy against old sys.	Root
-sN	Null Scan	No flags set. Bypasses some firewalls	Root
-sA	Ack Scan	Maps firewall rules, Not open ports	Root
-sW	Window Scan	Similar to ACK, checks TCP window size.	Root
-sM	Maimon Scan	FIN/ACK combo. works on BSD sys	Root

Post Sp...

DAY 10

- cyberwindspace.live -> webxploit
- Phone no. -> EPIOS
- TryHackMe Anonymous.

Home work
1. Road
2. Steel mountain

* Discord - cyberwindspace

SUNDAY LIVE CLASS

Module 13 : Web Server Fundamentals

Web server :- Software
- Client (browser) se HTTP/HTTPS request leta hai
- server par stored data / application se response bhejta hai.

Architecture
Browser
⇓
Web server (Apache / Nginx /).

Apache web Server

Apache HTTP server

web Browser request ↑ | ↓ we Browser serves the web page.

Web Browser.

3 modes of Apache :- 1. Prefork (1 request = 1 process). secure but use more RAM
2. Worker (1 process = multi threads) Better performance
3. Event (Non blocking) modern & fast

Client
↓
Apache Listener
↓
MPM (Prefork/Worker/Event)
↓
Modules (PHP, Auth Rewriter)
↓
Response.

Hacker mindset
- Server: Apache - easy fingerprinting.
- .htaccess misconfig -> auth bypass.
- Old Apache -> RCE / path traversal.

CVE

* CVE = Common Vulnerabilities and Exposures
* Public Database system in which whole world software and systems security vulnerabilities are given unique ID
* managed by MITRE Corporation
* eg. CVE - 2023 - 23397
* eg. Apache Log4j (CVE - 2021 - 44228)
  - RCE
  - Attacker can run their code in server
  - Billion + systems affected
* CVE Database → 1. MITRE CVE Database
  2. National Vuln Database (NVD)
  * NVD has more detailed data
    - CVSS score
    - Severity
    - Exploit details
    - Patch Info.
* CVSS = Common Vuln Scoring System
  0 - 10

Score	Severity
0 - 3.9	Low
4 - 6.9	Medium
7 - 8.9	High
9 - 10	Critical

* CVE Life Style
  1. Researcher discover vuln
  2. Researcher report to vendor
  3. Patch has been developed
  4. MITRE CVE assign
  5. Public disclosure
* Use as a pentester :-
  - Nmap scan
  - version detection
  - CVE mapping
* Practical workflow
  1. Service Detect
  2. version Identify
  3. CVE search
  4. CVSS check
  5. Exploit availability
  6. Test in Lab

CVE	Exploit
Vulnerability	Attack code
Information	Weapon
Public Data base	0 Day

* Deep dive
1. CNA (CVE Numbering Authority) - assigned by MITRE
2. 0 Day vuln - No CVE yet, No patch, High Risk
3. KEV catalog - CISA known exploited vulnerabilities
   - It tells which CVEs actively exploited

NIST :- National Institute of Standards and Technology

* US gov agency to make standards of security Rules & Guidelines.
  - cybersecurity
  - cryptography
  - Risk mgmt
  - Digital forensics
  - AI
  - cloud security.

* NIST cybersecurity framework (CSF)

5 core Functions (cyber security Life cycle mode)

1. Identify - Understand assets and risk
2. Protect - Put controls
3. Detect - To monitor
4. Respond - Incident handle
5. Recover - System restore.

Identify :-
- Assets List
- Risk assessment
- Vulnerabilities identify
- Business impact samjho

eg- which server is critical and which data is sensitive

2. Protect
- firewall -
- Access control -
- Encryption -
- Security Policies -

- Preventive control.

3. Detect
- SIEM
- Logs monitoring
- IDS / IPS
- Anomaly detection

4. Respond
- Incident response plan
- Forensics
- Containment
- Communication.

5. Recover
- Backup restore
- Business continuity
- Lesson Learned.

* Important NIST Publication
- NIST SP 800-53 :- Security controls detailed catalog.
- NIST SP 800-61 :- Incident Response Guide
- NIST SP 800-30 :- Risk Assessment Guide
- NIST SP 800-171 :- Gov contractors ke security requirements.

* NIST Cryptography :- It also make cryptography standards.
  - AES (Adv Enc Standard)
  - SHA-256
  - RSA guidelines

* CVE vs NIST :-

CVE	NIST
Vulnerabilities ID	Security Framework
MITRE	US Gov Agency
Problem	Sol Framework
Database	Standards

* Practical Cybersecurity NIST use

SOC Analyst	Pentester
• CSF se policy banana • SP 800-61 se incident handle karna • SP 800-53 se controls implement karna	• client ke controls NIST ke according evalute karna • Compliance testing karna

* NCSC :- National Cyber Security Centre
* UK National Cyber security Agency.
* NCSC is a part of GCHQ (Gov Comm HQ)
* NCSC Publish
  - SMEs security guides
  - Ransomware protection
  - Cloud security advice
  - Secure config checklist

* Cyber Essentials Certification :- Gov backed cert
  1. Firewalls
  2. Secure configuration
  3. User Access control
  4. Malware protection
  5. Patch mgmt.

NIST	NCSS
US standard body	UK cyber defence agency
Framework banana	Op response
Risk mgmt focus	National threat defence focus
Policy & controls	Active Incident handling

OSSTMM - Institute of Security and Open Methodologies (ISECOM)
- Open Source Security Testing Methodology Manual

* A scientific methodology which structured, measurable and repeatable formula based security testing and penetration testing kit made by ISECOM (Institute of Security & Open Methodologies).
* NIST - security framework
* OSSTMM - testing methodology.
* 5 security channels - (Holistic Approach)

Channel	Meaning
Human	Social Engineering
Physical	Physical access testing
Wireless	Wifi, Bluetooth
Telecom	Phone sys
Data N/W	Internet & Internal N/W

* Scientific Approach
  - Op security
  - measurable results
  - Risk calculation
  - Evidence-based reporting.
* RAV - Risk Assessment Value.

  Risk = controls - vulnerabilities + Trust + metrics

  - Different from CVSS.

*

Tradition Pentest	OSSTMM based test
Nmap scan	Human testing (phising simulation)
Exploit test	Physical access testing
Report vulnerabilities	Wireless audit
	Telecom audit
	N/W testing
	Trust relationship analysis
	Measurable risk score

* OSSTMM Report :
  - Facts based
  - No emotional language
  - No assumptions
  - No exaggeration

*

OSSTMM	NIST	OWASP
Testing methodology	Security framework	Web app focus
Scientific metrics	Policy & controls	App vulnerabilities
Op testing	Governance model	Dev security.

OSSTMM key concepts:

1. Op security :- test in actual op context
2. Trust Analysis :- trust misconfiguration = risk
3. Control Measurements :- to measure controls effectiveness

* Advance level insights :- High assurance testing required
  - Gov projects ho
  - military contracts ho
  - scientific audit required ho

→ rejects guess based hacking

* Eg: For Bank security Audit
  - ATM physical testing
  - Employee phishing test
  - Wifi audit
  - Telecom line audit
  - NW segmentation test
  - Trust boundary mapping.

* OSSTMM strength :- Evidence driven
  - Repetable methodology
  - Metrics based
  - Holistic coverage.

(continue)

SCANNING & ENUMERATION

3.4 Port Specification

Single port → nmap -p 80 <IP>
multiple ports → nmap -p 80,443,8080 <IP>
Port range → nmap -p 1-1000 <IP>
All 65535 ports → nmap -p U:53,T:80,443 <IP>
UDP and TCP mix → nmap -p <IP>.
Top 100 common ports → nmap --top ports 100 <IP>

Service & OS Detection

nmap -sV <IP> - service version detection
nmap -sV --version-intensity 9 <IP> - max intensity (slower)
nmap -O <IP> - OS detection (requires root).
nmap -O --osscan-guess <IP> - Aggressive OS guess
nmap -A <IP> - Aggressive: OS + version + scripts + traceroute
* -A is the go-to for CTFs and pentest reports. Combines -sV -O -sC -traceroute.

Nmap Scripting Engine (NSE)

nmap -sC <IP> → Default scripts
nmap --script=http-title <IP> → specific scripts
nmap --script=smb-vuln-* <IP> → All smb vuln scripts
nmap --script=vuln <IP> → All vuln scripts.
nmap --script=auth <IP> → Auth bypass scripts
nmap --script=http-enum <IP> → web dir enum
nmap --script=banner <IP> → Grab banners
nmap --script=smtp-enum-users <IP> → SMTP user enum
nmap -p 445 --script=smb-os-discovery <IP> → SMB OS discovery

Timing & Performance

* -T0 → Paranoid → Very slow → IDS evasion
-T1 → Sneaky → Slow → IDS evasion
-T2 → Polite → Slow → Low bandwidth
-T3 → Normal → Normal → Standard scanning
-T4 → Aggressive → Fast → Good network / CTFs
-T5 → Insane → Very fast → LAN only, may miss results

* nmap -T4 --min-rate 1000 --max-retries 3 <IP>/24

Evasion & Firewall Bypass

nmap -f <IP> → Fragment packets.
nmap --mtu 16 <IP> → Custom MTU (multiple of 8)
nmap -D RND:10 <IP> → Decoy scan (10 random IPs)
nmap -D <IP1>,<IP2>,ME <IP> → Custom decoys.
nmap -S 10.0.0.5 <IP> → Spoof source IP
nmap --source-port 53 <IP> → Spoof source port
nmap --data-length 25 <IP> → Append random data
nmap --randomize-hosts <IP>0/24 → Random host order
nmap --scan-delay 2s 192.161.1.1 → Delay b/w probes.

Output Formats

nmap -oN output.txt <IP> → Normal text output
nmap -oX output.xml <IP> → XML output
nmap -oG output-gnmap <IP> → Greapable output
nmap -oA output <IP> → All formats at once.
nmap -v <IP> → Verbose.
nmap -vv <IP> → Very verbose.

Ninja One Liner

* Full recon on a host
nmap -A -T4 -p- -oA full_scan <IP>.

* Quick host discovery then deep scan.
nmap -sn <IP.0./24> -oG- | awk '/Up/{print $2}' > live.txt && nmap -iL live.txt -sV -sC -oA deep.

* Stealth SYN scan with decoys
nmap -sS -T2 -f -D RND:5 --source-port 53 <IP>.

* SMB vulnerability check
nmap -p 445 --script=smb-vuln-ms17-010,smb-vuln-ms08-067 <IP 0./24>

ENUMERATION:- Enumeration goes deep into discovered services to extract actionable intelligence: usernames, shares, versions strings, SNMP data, DNS records, and more.

* DNS Enumeration:- can reveal subdomains, mail servers, zone transfers, and internal hostnames.